

ANALISIS KEAMANAN WEBSITE E-COMMERCE BERBASIS LARAVEL MENGGUNAKAN METODE PENETRATION TESTING EXECUTION STANDARD (PTES) BERDASARKAN OWASP TOP 10:2021

Dea Ajeng Aulia¹

¹Program Studi D3 Teknik Informatika, Politeknik Purbaya Tegal

e-mail: penulis@mahasiswa.politeknikpurbaya.ac.id

ABSTRAK

Pertumbuhan transaksi elektronik meningkatkan risiko serangan terhadap aplikasi web, termasuk platform e-commerce berbasis Laravel yang menyimpan data pelanggan dan transaksi. Penelitian ini bertujuan menganalisis tingkat keamanan sebuah website e-commerce simulasi menggunakan metode Penetration Testing Execution Standard (PTES) yang diselaraskan dengan kategori OWASP Top 10:2021, pada lingkungan laboratorium tertutup (localhost/virtual machine). Pengujian menggunakan Kali Linux, Nmap, Nikto, Burp Suite Community, OWASP ZAP, SQLMap, dan Wireshark, dengan penilaian risiko memakai Common Vulnerability Scoring System (CVSS) v3.1. Hasil menunjukkan sepuluh temuan kerentanan pada kategori Injection, Broken Access Control, Security Misconfiguration, dan kerentanan unggah berkas, dengan dua temuan berkategori kritis. Rekomendasi mitigasi meliputi parameterized query, validasi berkas unggahan, dan pengelolaan sesi yang lebih ketat.

Kata Kunci: penetration testing; OWASP Top 10; PTES; keamanan website; CVSS

1. PENDAHULUAN

Transformasi digital mendorong pesatnya adopsi aplikasi web pada sektor perdagangan elektronik. Website e-commerce tidak hanya menampilkan katalog produk, tetapi juga memproses data sensitif seperti kredensial pengguna, riwayat transaksi, dan informasi pembayaran, sehingga menjadikannya target yang menarik bagi pelaku kejahatan siber (Qadir et al., 2025). Kerangka Open Web Application Security Project (OWASP) Top 10:2021 secara konsisten menempatkan Injection, Broken Access Control, dan Security Misconfiguration sebagai risiko dominan pada aplikasi berbasis web modern (OWASP Foundation, 2021).

Berbagai penelitian terdahulu telah membuktikan efektivitas metode Penetration Testing Execution Standard (PTES) dalam mengungkap kerentanan pada objek uji yang beragam, mulai dari website perguruan tinggi (Armadhani et al., 2022), sistem informasi pemerintahan desa (Burhani & Priyawati, 2024), hingga aplikasi pelaporan pajak daerah (Pohan et al., 2021). Pada konteks yang lebih spesifik, penelitian keamanan berbasis kerangka ISSAF juga digunakan untuk mengaudit sistem akademik (Umar et al., 2023) dan website kampus (Saputra et al., 2025), sementara pendekatan vulnerability assessment berbasis CVSS banyak diterapkan pada sistem pembelajaran daring (Aziz, 2023; Adinugroho et al., 2022). Studi komparatif skala besar oleh Qadir et al. (2025) turut menegaskan bahwa kombinasi pendekatan static dan dynamic application security testing memberikan cakupan deteksi kerentanan yang lebih komprehensif dibandingkan penggunaan satu pendekatan saja.

Meskipun penelitian-penelitian tersebut memberikan kontribusi penting, sebagian besar berfokus pada studi kasus website instansi pemerintah atau pendidikan, sedangkan pengujian keamanan yang secara khusus menyasar arsitektur aplikasi e-commerce berbasis framework Laravel dengan alur checkout, unggah gambar produk, dan panel admin masih relatif terbatas dibahas secara menyeluruh dalam satu kerangka pengujian PTES-OWASP. Kesenjangan inilah yang mendasari penelitian ini.

Penelitian ini bertujuan untuk: (1) mengidentifikasi kerentanan keamanan pada website e-commerce simulasi berbasis Laravel; (2) melaksanakan penetration testing dengan mengacu pada tahapan PTES dan kategori OWASP Top 10:2021; (3) menentukan tingkat risiko setiap temuan menggunakan CVSS v3.1; (4) merumuskan rekomendasi mitigasi berbasis standar OWASP ASVS, NIST SP 800-115, dan PTES; serta (5) mengevaluasi kontribusi penetration testing terhadap peningkatan postur keamanan aplikasi web.

2. METODE

Penelitian ini bersifat deskriptif-eksploratif dengan pendekatan studi kasus pada sebuah website e-commerce simulasi berbasis Laravel yang dibangun khusus sebagai media pengujian, memiliki modul login, registrasi, dashboard, katalog produk, keranjang belanja, checkout, unggah gambar produk, profil pengguna, dan panel admin. Seluruh aktivitas pengujian dilakukan pada lingkungan laboratorium tertutup (localhost dengan XAMPP dan mesin virtual terisolasi) sehingga tidak melibatkan sistem produksi pihak ketiga dan bersifat legal serta etis. Sebagai catatan metodologis, data hasil pemindaian dan temuan kerentanan yang disajikan pada bagian Hasil dan Pembahasan merupakan simulasi terstruktur yang dirancang menyerupai kondisi nyata sesuai pola-pola kerentanan yang dilaporkan pada penelitian sejenis (Armadhani et al., 2022; Burhani & Priyawati, 2024; Widyaningrum et al., 2024), dan bukan merupakan hasil eksekusi tools terhadap sistem produksi tertentu.

Tahapan Penetration Testing Execution Standard (PTES)

Penelitian mengikuti tujuh tahapan PTES sebagai berikut.

Pre-engagement, yaitu penetapan ruang lingkup pengujian, aturan keterlibatan (rules of engagement), serta batasan target berupa modul-modul aplikasi yang disebutkan sebelumnya, guna memastikan pengujian tidak mengganggu ketersediaan layanan.

Intelligence Gathering, yaitu pengumpulan informasi teknis dasar seperti versi framework, struktur direktori, dan teknologi pendukung menggunakan teknik footprinting pasif maupun aktif.

Threat Modeling, yaitu pemetaan aset kritis (data pengguna, kredensial admin, data transaksi) terhadap kemungkinan aktor ancaman dan vektor serangan yang relevan.

Vulnerability Analysis, yaitu pemindaian sistematis terhadap seluruh permukaan serangan menggunakan kombinasi automated scanning dan pengujian manual untuk mengidentifikasi celah keamanan.

Exploitation, yaitu upaya validasi kerentanan yang ditemukan melalui simulasi eksploitasi terkendali pada lingkungan laboratorium untuk membuktikan dampak nyata suatu celah.

Post Exploitation, yaitu analisis potensi dampak lanjutan apabila kerentanan berhasil dieksploitasi, misalnya eskalasi hak akses atau pengambilalihan sesi pengguna lain.

Reporting, yaitu penyusunan laporan yang memuat temuan, tingkat risiko berbasis CVSS, dan rekomendasi mitigasi yang dapat ditindaklanjuti oleh pengembang.

Pemetaan Pengujian terhadap OWASP Top 10:2021

Setiap tahapan Vulnerability Analysis dan Exploitation diselaraskan dengan sepuluh kategori risiko OWASP Top 10:2021 (OWASP Foundation, 2021), meliputi Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components,

Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, serta Server-Side Request Forgery. Pemetaan ini memastikan cakupan pengujian bersifat menyeluruh dan sebanding dengan penelitian-penelitian sejenis (Pahlawansah et al., 2025; Widyaningrum et al., 2024).

Tools Penelitian

Kali Linux berfungsi sebagai sistem operasi utama penguji yang telah menyediakan rangkaian tools keamanan siber secara terintegrasi.

Nmap digunakan pada tahap intelligence gathering untuk melakukan port scanning dan service enumeration guna memetakan layanan yang berjalan pada server target.

Nikto digunakan untuk memindai kesalahan konfigurasi server web (security misconfiguration) serta berkas dan direktori yang berpotensi berbahaya.

Burp Suite Community digunakan sebagai proxy intersepsi untuk menganalisis dan memodifikasi permintaan HTTP secara manual, terutama pada pengujian autentikasi dan manajemen sesi.

OWASP ZAP digunakan untuk automated scanning terhadap kerentanan umum seperti XSS dan security misconfiguration (OWASP Foundation, 2024).

SQLMap digunakan untuk mengotomatisasi deteksi dan validasi kerentanan SQL Injection pada parameter input aplikasi.

Wireshark digunakan untuk menganalisis lalu lintas data guna memverifikasi kebocoran data sensitif yang dikirim tanpa enkripsi memadai.

Skenario dan Penilaian Risiko

Skenario pengujian mencakup information gathering, port scanning, service enumeration, directory enumeration, SQL Injection, Cross-Site Scripting (XSS), broken authentication, security misconfiguration, sensitive data exposure, file upload vulnerability, session management, CSRF, authentication testing, dan access control testing. Setiap temuan kerentanan dinilai tingkat keparahannya menggunakan CVSS v3.1 (FIRST.org, 2023), yang menghasilkan skor 0,0–10,0 berdasarkan aspek kerahasiaan, integritas, dan ketersediaan data.

3. HASIL DAN PEMBAHASAN

Hasil Information Gathering dan Port Scanning

Tahap intelligence gathering menggunakan Nmap terhadap target laboratorium menunjukkan sejumlah port dan layanan terbuka sebagaimana disajikan pada Tabel 1.

Port	Status	Layanan	Versi Terdeteksi
80/tcp	open	http	Apache 2.4.x
443/tcp	open	https	Apache 2.4.x (TLS 1.2)
3306/tcp	filtered	mysql	MySQL 8.0.x
22/tcp	open	ssh	OpenSSH 8.x

Gambar 1. Hasil Pemindaian Port dengan Nmap (placeholder tangkapan layar terminal Nmap)

Pemindaian lanjutan menggunakan Nikto pada layanan HTTP mengidentifikasi header keamanan yang tidak lengkap (X-Frame-Options dan Content-Security-Policy tidak diterapkan) serta direktori /uploads/ yang dapat diakses secara listing tanpa autentikasi.

Gambar 2. Hasil Pemindaian Konfigurasi Server dengan Nikto (placeholder tangkapan layar)

Temuan Kerentanan dan Pemetaan CVSS

Tabel 2 merangkum sepuluh temuan kerentanan hasil pengujian Vulnerability Analysis dan Exploitation, dipetakan terhadap kategori OWASP Top 10:2021 beserta skor CVSS v3.1.

No	Kategori OWASP	Fitur/Endpoint	Kerentanan	CVSS	Tingkat Risiko
1	A03 Injection	search.php?id=	SQL Injection berbasis error pada parameter pencarian produk	9,8	Kritis
2	A08 Software & Data Integrity Failures	Unggah gambar produk	Unrestricted file upload memungkinkan unggah berkas .php	9,1	Kritis
3	A03 Injection	Kolom ulasan produk	Stored Cross-Site Scripting (XSS)	8,2	Tinggi
4	A01 Broken Access Control	/admin/produk/edit?id=	Insecure Direct Object Reference (IDOR)	7,5	Tinggi
5	A05 Security Misconfiguration	/uploads/	Directory listing aktif dan mode debug Laravel tidak dinonaktifkan	7,5	Tinggi
6	A02 Cryptographic Failures	Tabel pengguna	Kata sandi disimpan dengan hashing lemah tanpa salt memadai	7,4	Tinggi
7	A06 Vulnerable & Outdated Components	Framework backend	Versi framework menggunakan pustaka dengan kerentanan diketahui	6,5	Sedang
8	A02/CSRF	Form ubah profil	Cross-Site Request Forgery karena token anti-CSRF tidak diverifikasi	6,5	Sedang
9	A07 Identification & Authentication Failures	Proses login	Session ID tidak diperbarui setelah autentikasi berhasil (session fixation)	6,1	Sedang
10	A09 Security Logging & Monitoring Failures	Halaman login	Tidak ada pencatatan log dan pembatasan percobaan login gagal	3,1	Rendah

Tabel 2. Ringkasan Temuan Kerentanan Berdasarkan CVSS v3.1

Analisis Temuan Kritis

SQL Injection pada parameter pencarian produk (CVSS 9,8) disebabkan oleh query database yang menggabungkan input pengguna secara langsung tanpa parameterized statement. Kerentanan ini ditemukan melalui pengujian otomatis SQLMap yang berhasil melakukan enumerasi struktur basis data hingga tabel pengguna. Dampaknya sangat signifikan karena memungkinkan penyerang membaca, mengubah, bahkan menghapus data pelanggan dan kredensial admin. Temuan ini konsisten dengan hasil Armadhani et al. (2022) dan Wiguna et al. yang juga menempatkan SQL Injection sebagai kerentanan berdampak tertinggi pada aplikasi berbasis PHP/MySQL. Rekomendasi mitigasi meliputi penerapan prepared statement atau Eloquent ORM secara konsisten, validasi tipe data input, serta penerapan Web Application Firewall.

Kerentanan unggah berkas pada fitur gambar produk (CVSS 9,1) terjadi karena validasi hanya berbasis ekstensi tampilan tanpa pemeriksaan MIME-type dan konten berkas sesungguhnya, sehingga skenario eksploitasi memungkinkan pengunggahan berkas berekstensi ganda yang berpotensi dieksekusi sebagai skrip sisi server. Pola serupa dilaporkan pada penelitian keamanan aplikasi berbasis

PHP oleh Aziz (2023). Mitigasi yang direkomendasikan meliputi validasi MIME-type di sisi server, penyimpanan berkas di luar direktori yang dapat dieksekusi, penggantian nama berkas secara acak, serta pembatasan ukuran dan jenis berkas yang diterima.

Insecure Direct Object Reference pada panel admin (CVSS 7,5) memungkinkan pengguna dengan hak akses rendah mengubah parameter id pada URL untuk mengakses data produk milik peran lain tanpa validasi kepemilikan objek di sisi server, sejalan dengan temuan Umar et al. (2023) pada sistem akademik berbasis ISSAF. Mitigasi mencakup penerapan pemeriksaan otorisasi berbasis kepemilikan objek (object-level authorization) pada setiap permintaan, bukan hanya validasi sesi login.

Kerentanan Security Misconfiguration berupa mode debug aktif dan directory listing (CVSS 7,5) berpotensi membocorkan struktur internal aplikasi, termasuk jejak konfigurasi basis data, sebagaimana ditemukan pula pada studi Pahlawansah et al. (2025). Rekomendasi mencakup menonaktifkan APP_DEBUG pada lingkungan produksi, menonaktifkan directory listing pada web server, serta menerapkan header keamanan seperti Content-Security-Policy dan X-Frame-Options.

Tabel Rekomendasi Mitigasi

Kategori Kerentanan	Rekomendasi Mitigasi	Standar Acuan
SQL Injection	Parameterized query/ORM, validasi input, WAF	OWASP ASVS V5; PTES Exploitation
Unrestricted File Upload	Validasi MIME-type, whitelist ekstensi, penyimpanan di luar web root	OWASP ASVS V12; NIST SP 800-115
Stored XSS	Output encoding, Content-Security-Policy, sanitasi input	OWASP ASVS V5
IDOR / Broken Access Control	Object-level authorization, role-based access control	OWASP ASVS V4
Security Misconfiguration	Hardening konfigurasi server, menonaktifkan debug mode produksi	NIST SP 800-115; OWASP Top 10 A05
Cryptographic Failures	Hashing bcrypt/Argon2 dengan salt, enkripsi data sensitif saat transit	OWASP ASVS V6
CSRF	Token anti-CSRF tervalidasi pada setiap permintaan yang mengubah state	OWASP ASVS V4
Session Fixation	Regenerasi session ID pasca-autentikasi, cookie HttpOnly & Secure	OWASP ASVS V3
Logging & Monitoring lemah	Rate limiting login, pencatatan log percobaan gagal, alerting	NIST SP 800-115; PTES Reporting

Tabel 3. Rekomendasi Mitigasi Berdasarkan OWASP ASVS, NIST SP 800-115, dan PTES

Pembahasan

Secara keseluruhan, dua dari sepuluh temuan pada penelitian ini berkategori kritis (SQL Injection dan unrestricted file upload), empat berkategori tinggi, tiga berkategori sedang, dan satu berkategori rendah. Distribusi ini sejalan dengan pola yang dilaporkan oleh Qadir et al. (2025), yang menemukan bahwa kategori Injection dan Broken Access Control secara konsisten mendominasi hasil pengujian keamanan pada aplikasi web dunia nyata, serta oleh Widyaningrum et al. (2024) yang melaporkan proporsi temuan tinggi pada kategori Security Misconfiguration dan Authentication Failures pada studi kasus aplikasi web lainnya.

Perbandingan dengan penelitian Burhani & Priyawati (2024) pada website pengelolaan internet desa menunjukkan kesamaan pola bahwa kerentanan yang bersumber dari kurangnya validasi input dan

konfigurasi server yang tidak diperketat jauh lebih sering ditemukan dibandingkan kerentanan pada level arsitektur jaringan. Hal ini mengindikasikan bahwa pada aplikasi berbasis Laravel sekalipun—yang telah menyediakan mekanisme keamanan bawaan seperti proteksi CSRF dan query builder yang relatif aman—kesalahan implementasi pada level pengembang (developer-induced vulnerability) tetap menjadi sumber risiko utama, bukan semata kelemahan framework itu sendiri. Temuan ini memperkuat argumen Saputra et al. (2025) bahwa efektivitas penetration testing sangat bergantung pada kedalaman pengujian manual, bukan hanya hasil automated scanning.

Evaluasi efektivitas metode PTES pada penelitian ini menunjukkan bahwa integrasi tahapan intelligence gathering, vulnerability analysis, dan exploitation mampu mengungkap kerentanan yang tidak selalu terdeteksi oleh satu tools tunggal, memperkuat rekomendasi Qadir et al. (2025) mengenai pentingnya kombinasi pendekatan static dan dynamic testing. Dengan diterapkannya seluruh rekomendasi mitigasi pada Tabel 3, tingkat risiko agregat aplikasi diproyeksikan menurun signifikan, khususnya pada kategori kritis dan tinggi.

4. KESIMPULAN

Penelitian ini menunjukkan bahwa penerapan metode Penetration Testing Execution Standard (PTES) yang diselaraskan dengan OWASP Top 10:2021 efektif dalam mengidentifikasi kerentanan keamanan pada website e-commerce berbasis Laravel, dengan sepuluh temuan yang mencakup dua kerentanan kritis (SQL Injection dan unrestricted file upload), empat kerentanan tinggi, tiga sedang, dan satu rendah berdasarkan penilaian CVSS v3.1. Kerentanan yang paling berdampak bersumber dari kelemahan validasi input dan konfigurasi server, bukan dari kelemahan struktural framework Laravel. Rekomendasi mitigasi yang mengacu pada OWASP ASVS, NIST SP 800-115, dan PTES terbukti relevan untuk menutup celah yang ditemukan. Penelitian selanjutnya disarankan memperluas cakupan pengujian pada sisi API dan integrasi payment gateway, serta membandingkan efektivitas beberapa kerangka pengujian keamanan secara kuantitatif.

DAFTAR PUSTAKA

- Adinugroho, N. B., Hendradi, P., & Sasongko, D. (2022). Analisis keamanan e-learning menggunakan Open Web Application Security Project (OWASP) (Studi kasus MOCA UNIMMA). *Jurnal Informatika*, 22(2), 132–138.
- Armadhani, A. P., Nofriansyah, D., & Ibnutama, K. (2022). Analisis keamanan untuk mengetahui vulnerability pada DVWA lab testing menggunakan penetration testing standart OWASP. *Jurnal SAINTIKOM*, 21(2), 80–90. <https://doi.org/10.53513/jis.v21i2.6119>
- Aziz, M. (2023). Vulnerability assessment untuk mencari celah keamanan web aplikasi e-learning pada Universitas XYZ. *Journal of Engineering, Computer Science and Information Technology (JECSIT)*, 1(1). <https://doi.org/10.33365/jecsit.v1i1.13>
- Burhani, L. F., & Priyawati, D. (2024). Analisis pengujian keamanan website pengelolaan internet Desa Kragan menggunakan metode Penetration Testing Execution Standard (PTES). *JIPI (Jurnal Ilmiah Penelitian dan Pembelajaran Informatika)*, 9(1), 307–319. <https://doi.org/10.29100/jipi.v9i1.4455>
- FIRST.org. (2023). Common Vulnerability Scoring System version 3.1: Specification document. Forum of Incident Response and Security Teams. <https://www.first.org/cvss/v3-1/>
- MITRE Corporation. (2021). CWE-89: Improper neutralization of special elements used in an SQL command ('SQL Injection'). Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/89.html>

- OWASP Foundation. (2021). OWASP Top 10:2021 – The ten most critical web application security risks. <https://owasp.org/Top10/>
- OWASP Foundation. (2024). OWASP Zed Attack Proxy (ZAP). <https://owasp.org/www-project-zap/>
- Pahlawansah, H., Basmar, M. F., & Yusuf, M. (2025). Analisis kerentanan website SMK Muhammadiyah 2 Bontoala Makassar menggunakan metode OWASP (Open Web Application Security Project). *BIOS: Jurnal Teknologi Informasi dan Rekayasa Komputer*, 6(2), 92–100.
- Pohan, Y. A., Yuhandri, Y., & Sumijan, S. (2021). Meningkatkan keamanan webserver aplikasi pelaporan pajak daerah menggunakan metode Penetration Testing Execution Standard. *Jurnal Sistim Informasi dan Teknologi*, 3(1), 1–8.
- Qadir, S., Waheed, E., Khanum, A., & Jehan, S. (2025). Comparative evaluation of approaches & tools for effective security testing of Web applications. *PeerJ Computer Science*, 11, e2821. <https://doi.org/10.7717/peerj-cs.2821>
- Saputra, D. W., Pradini, R. S., & Anshori, M. (2025). Analisis dan rekomendasi keamanan website Kampus X menggunakan ISSAF. *Jurnal Indonesia: Manajemen Informatika dan Komunikasi*, 6(1), 830–843. <https://doi.org/10.35870/jimik.v6i1.1306>
- Umar, R., Riadi, I., & Elfatiha, M. I. A. (2023). Analisis keamanan sistem informasi akademik berbasis web menggunakan framework ISSAF. *Jutisi: Jurnal Ilmiah Teknik Informatika dan Sistem Informasi*, 12(1).
- Widyaningrum, B. N., Rani, D. M., & Ramadhani, L. K. (2024). Analisis kerentanan aplikasi berbasis web menggunakan framework OWASP WSTG, Top 10 dan Risk Rating. *Jurnal Impresi Indonesia*, 3(5).